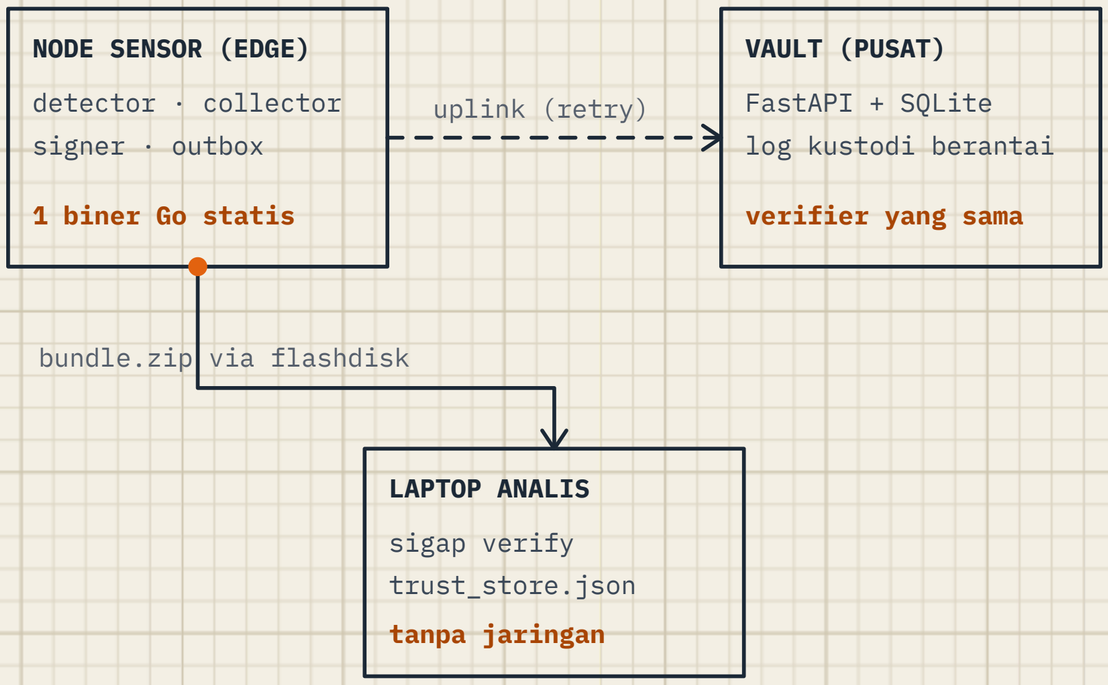
KARTIKA CYBER HACKATHON 2026 · KATEGORI DUKUNGAN TEKNOLOGI

SIGAP

Sistem Integritas Gerak-cepat untuk Akuisisi Pembuktian

Purwarupa forensik IoMT yang offline-first. Node mendeteksi anomali, mengumpulkan artefak, dan menandatangani bundle bukti. Keasliannya bisa diperiksa **tanpa server pusat**.

DIGITAL FORENSIC TOOLKIT | GO + PYTHON | ED25519 | OFFLINE-FIRST



Bukti hilang sebelum analis tiba

Sensor lapangan jarang terhubung stabil ke pusat. Saat terjadi insiden, bukti volatil seperti proses dan koneksi harus diamankan dalam hitungan detik. Pada saat itu sering belum ada personel forensik di lokasi.

SIAPA

Operator satuan yang mengelola sensor, analis forensik tim siber, dan auditor yang menilai rantai kustodi.

APA

Artefak live response dari node IoMT: daftar proses, koneksi jaringan, log, konfigurasi, dan peringatan detektor.

DI MANA

Pos terdepan dan kendaraan dengan link **DDIL** (disconnected, intermittent, limited).

KAPAN

Detik-detik setelah anomali muncul, sebelum proses berhenti dan log tertimpa.

MENGAPA

Tanpa hash dan tanda tangan sejak awal, keaslian bukti mudah dibantah dan perubahan tidak terdeteksi.

BAGAIMANA SEKARANG

Salin manual, catatan kustodi di kertas, dan verifikasi yang menunggu koneksi ke pusat.

Catatan metode: hasil riset meja tim, belum divalidasi lewat wawancara pengguna. Validasi direncanakan pada siklus HCD berikutnya (slide 05).

Peluang ada di kebutuhan yang belum dilayani

Kebutuhan	Dilayani alat yang ada	Belum dilayani
Tak terucap	**DILAYANI** – Mencatat siapa memegang bukti. Saat ini memakai formulir kustodi kertas yang mudah ditulis ulang.	UNEXPLOITED **BELUM TERGARAP** – Menolak bukti bertanda tangan kunci sah milik penyerang. – Mendeteksi admin yang menulis ulang log kustodi. – Menyamarkan kredensial sebelum di-hash.
Terucap	**DILAYANI** – Mengumpulkan artefak live response pada host yang terhubung (UAC, Velociraptor). – Menghitung hash berkas bukti secara manual.	OPPORTUNITIES **PELUANG** – Koleksi otomatis saat link ke pusat terputus. – Verifikasi keaslian tanpa server pusat. – Agen ringan untuk ARM tanpa runtime tambahan.

Fokus SIGAP: dua kuadran kanan.

Kuadran kiri sudah dilayani alat yang ada. SIGAP tidak menggantikan Velociraptor, UAC, atau Autopsy.

Kuadran **belum tergarap** jarang diminta pengguna, tetapi menjadi pembeda saat keaslian bukti diuji.

Tiga peran, satu bukti yang sama

Operator satuan

mengelola sensor di lapangan

TUJUAN

Mengamankan bukti dengan cepat walaupun tidak punya keahlian forensik.

HAMBATAN

Link sering putus dan tidak ada analis di lokasi.

DIJAWAB SIGAP

Koleksi berjalan otomatis saat aturan terpicu. Bundle menunggu di outbox sampai link pulih.

Analis forensik

memeriksa bukti di laptop

TUJUAN

Memastikan bukti asli sebelum menghabiskan waktu untuk menganalisisnya.

HAMBATAN

Bukti datang lewat flashdisk tanpa jaminan keaslian.

DIJAWAB SIGAP

Satu perintah `sigap verify` secara offline, lengkap dengan status dan alasan yang jelas.

Auditor

menilai rantai kustodi

TUJUAN

Menelusuri siapa menyentuh bukti, kapan, dan apa hasilnya.

HAMBATAN

Catatan kertas dan database biasa bisa ditulis ulang tanpa jejak.

DIJAWAB SIGAP

Timeline kustodi berantai hash. Tombol "Periksa rantai" menunjukkan entri yang diubah.

Proto-persona disusun dari asumsi tim. Ini bukan data wawancara dan bukan representasi personel tertentu.

Sudah tahap mana, dan apa buktinya

1
PAHAMI KONTEKS
5W + 1H, matriks kebutuhan, dan proto-persona.

SELESAI

2
TETAPKAN KEBUTUHAN
Jaminan dan batas klaim ditulis di README dan threat model.

SELESAI

3
RANCANG SOLUSI
Purwarupa berjalan: agen, vault, dashboard, dan demo Docker.

SELESAI

4
EVALUASI
Evaluasi heuristik dan analisis jalur sudah dilakukan. Uji dengan pengguna nyata belum.

SEBAGIAN

iterasi: temuan evaluasi kembali ke kebutuhan dan rancangan

RENCANA UJI PENGGUNA
- 5 responden per peran, masing-masing 3 tugas inti.
- Metrik: task success, time-on-task, dan skor SUS.
- Target: SUS ≥ 68 dan lostness < 0,4.

TUGAS INTI YANG DIUJI
- Memastikan satu bundle asli dari dashboard.
- Memverifikasi bundle offline dari terminal.
- Memeriksa apakah log kustodi diubah.

Lima langkah, tanpa campur tangan operator

Alur ini berjalan di node. Hanya langkah terakhir yang membutuhkan manusia.



Deteksi

Enam aturan: reverse shell, egress di luar allowlist, port baru, perubahan config, lonjakan CPU, dan eksekusi dari /tmp.

`interval 2 detik`



Koleksi

Membaca /proc langsung, tanpa ps atau ss yang mungkin sudah dimodifikasi. Kredensial disamarkan sebelum di-hash.

`6 artefak per bundle`



Tanda tangan

SHA-256 setiap artefak masuk ke manifest. Manifest ditandatangani Ed25519 dalam berkas terpisah.

`kunci privat mode 0600`



Simpan & teruskan

Bundle menunggu di outbox. Uplink dicoba ulang dan tidak pernah menunda deteksi.

`tahan DDIL`



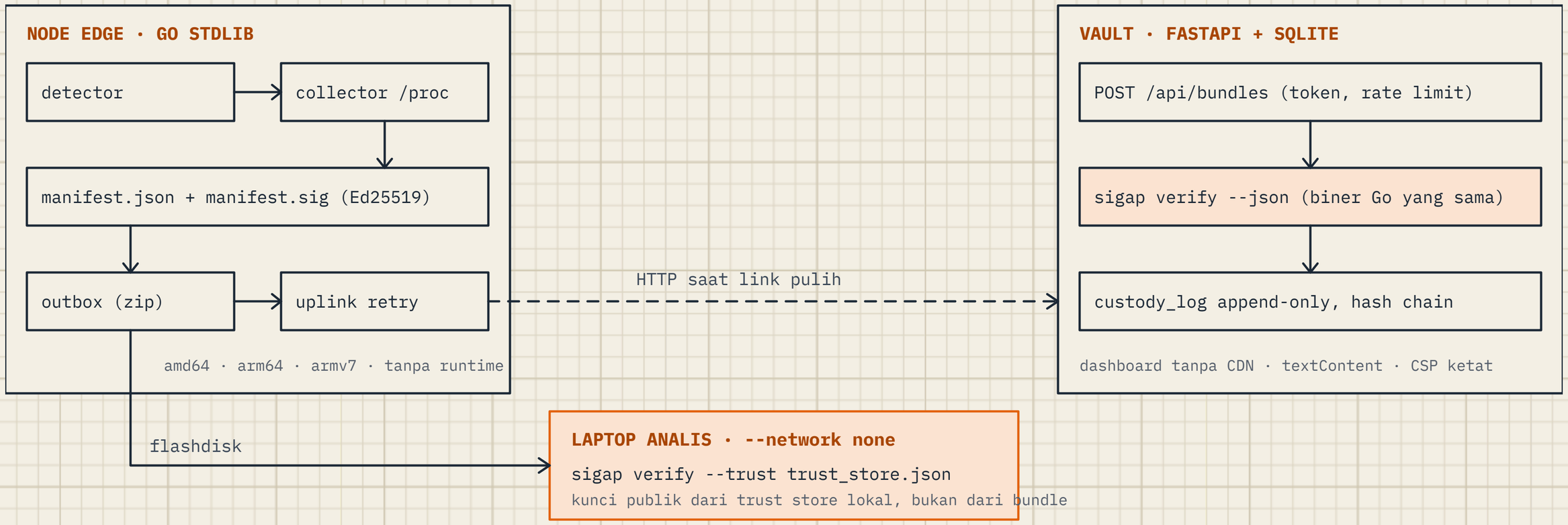
Verifikasi

Analis memeriksa bundle offline. Vault memeriksa ulang dengan biner Go yang sama, lalu mencatat kustodi.

`satu implementasi`

Prinsip wayfinding: setiap langkah punya satu piktogram yang dipakai konsisten di slide, dokumentasi, dan demo.

Satu verifier untuk node, laptop, dan vault



Vault tidak pernah membuka zip sendiri. Hasil VALID atau TAMPERED tidak mungkin berbeda antara lapangan dan pusat.

Dari strategi abstrak ke tampilan konkret

KONKRET

ABSTRAK

BIDANG	KEPUTUSAN DI SIGAP	BUKTI DI REPOSITORI
5 · Surface	Dashboard gelap dengan kontras tinggi. Warna status selalu disertai teks status. Font mono untuk hash.	`vault/static/style.css`
4 · Skeleton	Satu halaman: tabel bundle di atas, detail di bawah. Aksi audit "Periksa rantai" selalu terlihat di header.	`vault/static/index.html`
3 · Structure	Lima status yang sama di CLI, exit code, API, dan dashboard. Waktu node ditandai "dilaporkan sendiri".	`internal/verify, app.js`
2 · Scope	Koleksi otomatis, verifikasi offline, dan log kustodi. Analisis mendalam, ML, dan GUI node tidak termasuk.	`README "Batas klaim"`
1 · Strategy	Bukti dari node lapangan tetap bisa dipertanggungjawabkan walaupun tidak ada koneksi dan tidak ada analis di lokasi.	`docs/threat_model.md`

Lima rambu di titik keputusan analis

Setelah verifikasi, analis harus memutuskan satu hal: lanjut menganalisis atau tidak. Setiap status adalah rambu dengan arti dan tindakan yang tetap.

	STATUS	EXIT	ARTI	TINDAKAN ANALIS
	VALID	0	Tanda tangan sah dari kunci di trust store dan semua hash cocok	Lanjutkan analisis
	TAMPERED	2	Byte berubah atau ada berkas tak terdaftar	Karantina, laporkan, minta salinan baru
	INCOMPLETE	3	Berkas yang tercantum di manifest hilang	Minta bundle utuh dari outbox node
	UNTRUSTED_SIGNER	4	Kunci tidak ada, dicabut, atau kedaluwarsa	Periksa trust store dan asal bundle
	MALFORMED	5	Bukan zip, nama berbahaya, symlink, atau bom dekompresi	Jangan diekstrak, simpan sebagai sampel

Jelas
Status satu kata, alasan dalam bahasa Indonesia.

Di titik keputusan
Status muncul di baris pertama keluaran.

Konsisten
Kosakata sama di CLI, API, dan dashboard.

Aksesibel
Warna selalu disertai teks dan bentuk piktogram.

Sepuluh skenario, sepuluh hasil yang sesuai

SKENARIO	HASIL	WAKTU
Bundle asli dari node	VALID	935 µs
Ubah 1 byte artefak	TAMPERED	968 µs
Tambah berkas tak terdaftar	TAMPERED	810 µs
Hapus berkas terdaftar	INCOMPLETE	821 µs
Ubah manifest	TAMPERED	624 µs
Ganti tanda tangan	TAMPERED	681 µs
Zip slip `../../etc/cron.d`	MALFORMED	127 µs
Entri symlink	MALFORMED	79 µs
Bom dekompresi 110 MB	MALFORMED	606 µs
Kunci Ed25519 sah milik penyerang	UNTRUSTED_SIGNER	177 µs

DI VAULT (API)

- Hasil sama persis dengan verifikasi offline.
- Replay bundle asli dicatat `duplicate_ignored`.
- Unggahan tanpa token ditolak `HTTP 401`.
- Rantai 9 entri utuh. Setelah satu entri diubah, rantai **PUTUS di entri #4**.

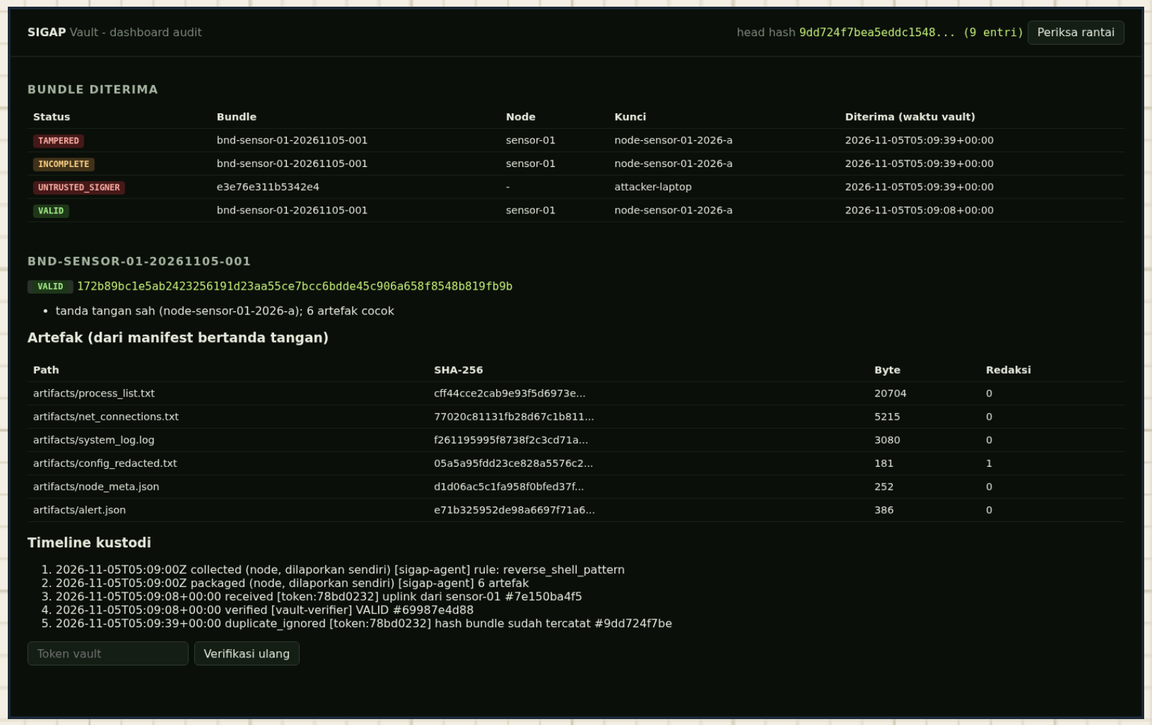
OTOMATIS

`go vet · go test · pytest · docker compose build`

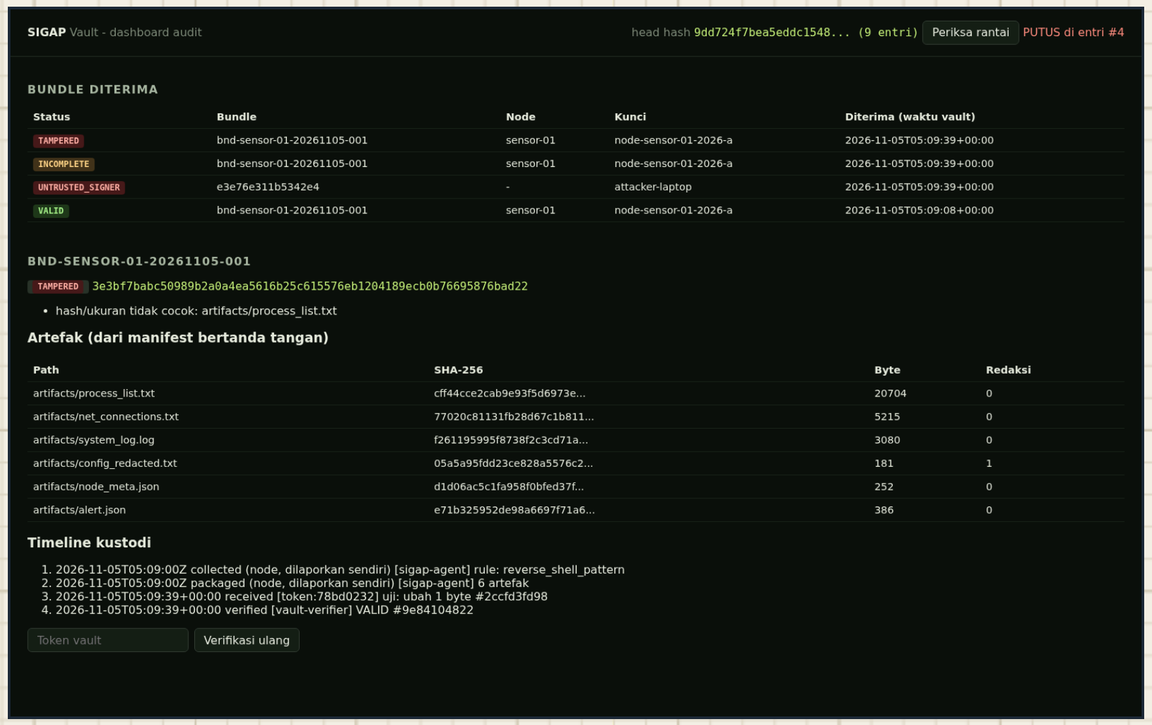
Workflow GitHub Actions untuk setiap push.

Keluaran asli dari run 5 Nov 2026 ada di docs/bukti_demo.md. Waktu diukur pada satu mesin dan bukan benchmark.

Dashboard audit vault



Bundle VALID. Enam artefak dari manifest bertanda tangan. config_redacted mencatat 1 redaksi. Peristiwa node ditandai "dilaporkan sendiri".



Admin menulis ulang SQLite. TAMPERED diubah menjadi VALID. "Periksa rantai" menampilkan **PUTUS di entri #4**.

Sudah baik, dan yang perlu diperbaiki

SUDAH MEMENUHI

- **H1 Visibilitas status.** Badge status, alasan, dan head hash selalu tampil.
- **H2 Dunia nyata.** Istilah forensik dalam bahasa Indonesia, dan waktu node diberi label jujur.
- **H4 Konsistensi.** Lima status yang sama di semua permukaan.
- **H5 Cegah kesalahan.** Token wajib untuk unggahan, dan replay tidak diproses ulang.

TEMUAN, MASUK BACKLOG

- **H6 Recognition.** Bundle asli dan manipulasi memakai bundle_id yang sama. Perlu kolom hash pendek.
- **H1 / H10.** Tabel kosong tanpa pesan dan belum ada legenda status.
- **H9 Pulihkan galat.** Galat verifikasi ulang tampil sebagai alert mentah.
- **Aksesibilitas.** Baris tabel belum bisa dipilih dengan keyboard.

LOSTNESS

$$L = \sqrt{((N/S-1)^2 + (R/S-1)^2)}$$

Tugas "pastikan bundle asli": N = 2, S = 2, R = 2, sehingga **L = 0**.

analisis jalur, bukan uji pengguna

DOHERTY < 400 MS

Verifikasi butuh 79 µs sampai 968 µs. Hick: layar utama hanya punya 2 aksi.

Mudah dipasang di satuan, jujur soal batasnya

PENERAPAN

- Satu biner statis untuk amd64, arm64, dan armv7.
- Kit offline lengkap dengan SHA256SUMS dan wheelhouse.
- Demo Docker di jaringan internal tanpa akses internet.
- Agen tanpa dependensi pihak ketiga.

DIJAMIN

- Perubahan, penambahan, atau penghapusan setelah bundle ditandatangani pasti terdeteksi.
- Kunci penyerang tidak bisa diselundupkan.
- Penulisan ulang log kustodi terdeteksi.

TIDAK DIJAMIN

- Kebenaran isi bukti dari node yang sudah dikuasai.
- Pencurian kunci dari node.
- Waktu yang dilaporkan node.
- Penerimaan bukti di proses hukum.

ROADMAP

R1 Kunci node di TPM atau secure element

R2 Cap waktu tepercaya RFC 3161

R3 Tanda tangan pasca-kuantum ML-DSA

R4 Perbaikan UX dari temuan heuristik dan uji SUS

Juri bisa mencobanya dalam 3 menit

```
# butuh Docker Compose v2 dan curl
$ git clone \
  https://github.com/Daxxiee0x1/SIGAP.git
$ cd SIGAP
$ make up
# buka http://127.0.0.1:8000
$ make inject-reverse_shell
$ make logs
$ make tamper-demo

# demo penuh sesuai video:
$ AUTO=1 make demo
```

- **make up** menjalankan vault, sensor-01, dan sink di jaringan Docker internal.
- **inject** menjalankan simulasi aman. Hanya proses tidur berpola, tanpa koneksi sungguhan.
- **tamper-demo** memverifikasi bundle terbaru beserta 8 manipulasinya tanpa Go atau Python di host.

Panduan lengkap, cara tanpa Docker, hasil yang diharapkan, dan penanganan masalah ada di `docs/cara_mencoba.md`.

Di mana juri menemukan buktinya

KRITERIA	BOBOT	BUKTI UTAMA
Relevansi dan manfaat	25%	Konteks DDIL, matriks kebutuhan, dan proto-persona (slide 02–04)
Inovasi teknis	25%	Satu verifier untuk node, laptop, dan vault. Redaksi sebelum hash. Log kustodi berantai (slide 06–07)
Fungsionalitas purwarupa	25%	10 skenario lolos, demo Docker satu perintah, dan tangkapan layar asli (slide 10–11)
Kelayakan implementasi	15%	Biner statis multi-arsitektur, kit offline, batas klaim, dan roadmap (slide 13)
Kualitas dokumentasi	10%	README, arsitektur, threat model, bukti demo, dan cara mencoba

Bukti yang tidak bisa diuji tidak bisa dipercaya.
SIGAP membuat setiap bukti bisa diuji, bahkan tanpa koneksi.